

Plan de Pruebas de Calidad, Seguridad y Cumplimiento

Sistema de exámenes médicos **Cuidarte+**
Evaluación Parcial 1 (EP1) — ISY1102 Calidad y Seguridad en el Desarrollo de
Software

Documento base: *Cuidarte+* — *Especificación de Requerimientos de Software* (CreaLab Spa), v1.1. Código fuente analizado:
CodigoFuenteB (BACKEND Express + PostgreSQL / FRONTEND React).
Tipo de análisis: revisión estática de código y de la ERS (sin ejecución dinámica).

1. Control de versiones del documento

Fecha	Versión	Autor	Descripción
2026-09-09	1.0	Equipo de QA	Elaboración del plan de pruebas a partir de la ERS v1.1 y de la revisión estática del código fuente entregado.

2. Introducción

2.1 Propósito

Este plan define la estrategia, el alcance, los recursos, los casos de prueba y los criterios de aceptación para verificar que el sistema **Cuidarte+** cumple con sus requisitos funcionales (RF) y no funcionales (NFR), con los estándares de calidad y seguridad de la asignatura ISY1102 y con la normativa chilena de protección de datos personales. El plan integra tres dimensiones inseparables: **calidad** (¿el software hace lo que debe y lo hace bien?), **seguridad** (¿protege la confidencialidad, integridad y disponibilidad de la información clínica?) y **cumplimiento** (¿se adhiere a leyes y estándares aplicables?).

2.2 Alcance

En alcance: API REST del backend (autenticación, usuarios, pacientes, exámenes, documentos, roles y auditoría), la SPA React (login, registro, dashboards por rol, gestión de pacientes/exámenes, visualización y descarga de documentos, auditoría), el modelo de datos PostgreSQL y los controles de seguridad transversales (cifrado, control de acceso por rol, gestión de logs, respaldo).

Fuera de alcance: pruebas de infraestructura de despliegue en la nube, integración real de correo electrónico, pruebas de aceptación de usuario con adultos mayores en terreno y auditoría externa de certificación. La ejecución dinámica (docker-compose) queda fuera de este entregable; los casos se especifican para ejecución posterior.

2.3 Referencias

- ERS *Sistema de exámenes médicos Cuidarte+*, v1.1 (secciones 3.2 RF, 3.3 NFR, 3.4 Reglas de negocio, 4 Arquitectura).
- Materia ISY1102: pruebas funcionales y no funcionales; auditoría de calidad y legalidad; elaboración de un plan de pruebas de calidad, seguridad y cumplimiento.
- ISO/IEC 25010 (modelo de calidad del producto), ISO/IEC 27001 (SGSI), OWASP Top 10.
- Ley N° 19.628 y Ley N° 21.719 (protección de datos personales), Ley N° 21.663 (ciberseguridad).

3. Estrategia de pruebas

3.1 Niveles de prueba

Nivel	Objetivo en Cuidarte+
Unitarias	Validaciones Yup, utilidades (normalizeRut), lógica de autorización por rol (requireRole).
Integración	Endpoints REST contra PostgreSQL: flujos auth->roles->pacientes->exámenes->documentos->auditoría.
Sistema	Flujos completos end-to-end por rol (admin, médico, paciente, anónimo) sobre la SPA + API.
Aceptación	Verificación de criterios de aceptación de la ERS y de reglas de negocio RB-1..RB-3.

3.2 Tipos de prueba

- **Funcionales** (el 'qué hace'): un caso por requisito funcional RF-1 a RF-5, con datos válidos, inválidos y de borde.
- **No funcionales** (el 'cómo lo hace'): rendimiento (NFR-PERF), usabilidad/accesibilidad (NFR-USAB), disponibilidad (NFR-DIS), compatibilidad (NFR-COMPAT).
- **Seguridad**: control de acceso por rol, cifrado en tránsito y reposo, hashing de contraseñas, protección CSRF/XSS/SQLi, gestión de sesión (JWT), gestión de logs, fuerza bruta, IDOR y escalamiento de privilegios.
- **Cumplimiento**: adherencia a Ley 19.628/21.719 (minimización, consentimiento, derechos del titular, eliminación lógica), integridad del registro de auditoría y trazabilidad requisito<->caso<->evidencia.

3.3 Técnicas

Caja negra sobre la API y la SPA (partición de equivalencia, valores límite, tablas de decisión por rol), complementada con revisión estática de código (SAST manual) para localizar defectos de seguridad y mantenibilidad, y pruebas basadas en riesgo priorizando datos clínicos y autenticación.

3.4 Herramientas propuestas

Herramienta	Uso
Postman / Newman	Colección de pruebas de la API a partir de openapi.json; pruebas de contrato y regresión.
Jest + Supertest	Pruebas de integración automatizadas de endpoints Express.
OWASP ZAP	Escaneo dinámico de vulnerabilidades (XSS, cabeceras, CSRF, TLS).
sqlmap	Verificación puntual de inyección SQL en parámetros de ruta y query.
k6 / JMeter	Pruebas de carga y rendimiento (NFR-PERF-1..3).
Lighthouse / axe-core	Auditoría de accesibilidad y rendimiento del frontend (NFR-USAB, NFR-PERF-2).
npm audit / ESLint	Análisis estático de dependencias y de código.
Testcontainers / Docker	Entorno de base de datos PostgreSQL efímero para pruebas de integración.

3.5 Criterios de entrada y salida

	Criterio
Entrada	Código compila y levanta (docker-compose up); base de datos inicializada con init.sql; colección de API disponible; ambiente de pruebas aislado.

	Criterio
Salida	100% de los casos de prioridad Alta ejecutados; 0 defectos críticos o altos abiertos de seguridad; requisitos RF-1..RF-5 y NFR con al menos un caso aprobado o con desviación documentada y aceptada; matriz de trazabilidad completa.

3.6 Criterios de aceptación (ERS)

- Login exitoso genera token JWT; logout invalida la sesión (RF-1).
- Operaciones CRUD validan la entrada; la eliminación es lógica y con confirmación (RF-3).
- Subida y descarga de documentos en menos de 10 s (RF-4.4).
- Se genera un registro de auditoría por cada acción crítica (RF-5).
- CRUD simple < 300 ms y home < 2 s en móvil (NFR-PERF-1/2).
- Auditoría de seguridad con checklist y pruebas de penetración sin hallazgos críticos (NFR-SEG).

4. Casos de prueba funcionales (RF-1 a RF-5)

Prioridad: A=Alta, M=Media. Los casos marcados con (D) exponen una desviación esperada respecto a la ERS, confirmada en la revisión estática (ver sección 8).

ID	Requisito	Escenario / Pasos	Datos	Resultado esperado	Pri o
CP-F-01	RF-1.1	POST /autenticacion/login con usuario y contraseña correctos	admin / admin	200; cuerpo {token} con JWT válido (exp 2h); se inserta fila en auditoria ('LOGIN')	A
CP-F-02	RF-1.1	Login con contraseña incorrecta	admin / xxx	401 'Credenciales inválidas'; sin token	A
CP-F-03	RF-1.1	Login con campos faltantes o usuario < 3 caracteres	{ }	400 'Error de validación' con detalle de campos	A
CP-F-04 (D)	RF-1.2	Cerrar sesión y reutilizar el token anterior en un endpoint protegido	token válido pre-logout	El token debe ser rechazado (401). Desvío: el JWT sigue siendo válido hasta su expiración; no hay revocación en servidor	A
CP-F-05	RF-2.1	POST /autenticacion/registro de usuario nuevo	usuario/correo únicos, pass 8+	201; usuario creado con rol 'paciente' por defecto; fila en auditoria ('REGISTRO')	A
CP-F-06	RF-2.1	Registro con nombre de usuario o correo ya existente	correo repetido	400 'Usuario o correo duplicado'	A
CP-F-07 (D)	RF-2.1 / 2.4 (Restr.)	Registro con contraseña de 6 caracteres sin mayúscula/número/símbolo	'abcdef'	Debe rechazarse: política ERS = mínimo 12 con complejidad. Desvío: el sistema acepta (registerSchema exige solo min 6)	A
CP-F-08	RF-2.2	Médico o admin registra un paciente	RUT válido + datos obligatorios	201; paciente persistido; auditoria ('PACIENTES_CREAR')	A
CP-F-09	RF-2.2 / RB-1	Usuario con rol 'paciente' intenta crear un paciente	token de paciente	403 'No autorizado'	A
CP-F-10	RF-2.3	Médico edita datos de un paciente	PUT /pacientes/:id campos válidos	200; cambios persistidos; auditoria ('PACIENTES_ACTUALIZAR')	A
CP-F-11	RF-2.4	Médico visualiza el registro de un paciente	GET /pacientes/:id	200 con ficha del paciente	A
CP-F-12	RF-2.5	Admin lista usuarios / no-admin lo intenta	GET /usuarios	Admin: 200 lista; médico o paciente: 403	A
CP-F-13	RF-2.6	Admin edita un usuario y le asigna otro rol	PUT /usuarios/:id { rol_id }	200; rol actualizado en usuario_rol; auditoria	A
CP-F-14 (D)	RF-2.7	Admin elimina un usuario	DELETE /usuarios/:id	200 { deleted:true }. Desvío: el endpoint no valida token ni rol (cualquiera puede eliminar); ver CP-SEG-03	A
CP-F-15	RF-3.1	Médico registra un examen a un paciente	POST /exámenes datos válidos	201; examen persistido; auditoria ('EXAMENES_CREAR')	A
CP-F-16	RF-3.2	Médico edita datos del examen y actualiza el documento asociado	PUT /exámenes/:id + POST /documentos	200 / 201; cambios persistidos	A
CP-F-17 (D)	RF-3.3	Eliminar un examen médico	DELETE /exámenes/:id	Debe ser eliminación lógica con confirmación previa (criterio RF-3). Desvío: es DELETE físico e inmediato, sin borrado lógico	A
CP-F-18	RF-4.1 / RB-1	Paciente visualiza sus exámenes; no ve los de otros	GET /exámenes con token paciente	200; solo exámenes cuyo paciente_id corresponde a su usuario	A
CP-F-19	RF-4.2	Paciente descarga el documento de su examen	GET /documentos/:id	200; archivo con Content-Disposition attachment	A
CP-F-20 (D)	RF-4.3	Médico adjunta documentos en PDF, DOC, PPT, JPG y PNG	upload por formato	PDF/JPG/PNG: 201. Desvío: DOC y PPT son rechazados (fileFilter solo admite pdf/jpeg/png)	A

ID	Requisito	Escenario / Pasos	Datos	Resultado esperado	Prioridad
CP-F-21	RF-4.4	Verificar que el documento queda en storage y referenciado en BD	consulta a documentos_examen	Fila con documento (BYTEA) y nombre_archivo; subida+descarga < 10 s	A
CP-F-22 (D)	RF-5.1	Cada acción crítica genera registro de auditoría	crear/editar/eliminar de cada entidad	Registro por acción. Desvío: DELETE /usuarios y rutas /roles insertan nombre de usuario (texto) en auditoria.usuario_id (BIGINT FK) -> el INSERT falla y la acción no queda auditada	A

5. Casos de prueba no funcionales

ID	Requisito	Escenario / Pasos	Datos	Resultado esperado	Prioridad
CP-NF-01 (D)	NFR-PE RF-1	Medir latencia de CRUD simple (GET /pacientes, GET/POST /exámenes, POST /documentos) bajo carga normal	50 req/s	p95 < 300 ms. Desvío: delayMiddleware(5000) introduce 5 s artificiales en esos endpoints	A
CP-NF-02	NFR-PE RF-2	Tiempo de carga de la página principal en 3G/4G simulado (Lighthouse)	perfil móvil	First Contentful Paint / carga < 2 s	M
CP-NF-03	NFR-PE RF-3	Prueba de carga con 200 usuarios concurrentes (k6)	200 VUs, 10 min	Sin errores 5xx; tasa de error < 1%; latencia estable	M
CP-NF-04	NFR-US AB-1 / 3.1.1	Revisar tipografía legible, contraste AA y controles de tamaño táctil	axe-core + inspección	Cumple WCAG AA básico; fuente base >= 12 px; objetivos táctiles >= 44 px	M
CP-NF-05	NFR-US AB-4	Flujo escalonado: primero seleccionar paciente, luego ver sus exámenes	navegación médico	La UI obliga a elegir paciente antes de listar exámenes	M
CP-NF-06	NFR-DIS -1	Verificar objetivo de disponibilidad y ventana de mantenimiento	monitoreo / diseño	Diseño soporta 99,5%/mes; procedimiento de actualización con migración segura documentado	B
CP-NF-07	NFR-CO MPAT-1/ 2	Ejecutar suite E2E en Chrome, Firefox, Safari y Edge (2 últimas versiones) y en viewport móvil/tablet	matriz navegadores	Funcionalidad y layout correctos en todos	M
CP-NF-08 (D)	NFR-US AB-3 / NFR-SEG-6	Provocar un error de servidor y observar el mensaje mostrado al usuario	payload que rompa una query	Mensaje amigable y genérico. Desvío: la respuesta incluye 'glosa' con err.message (detalle técnico); el frontend lo muestra en un toast	A

6. Casos de prueba de seguridad

Referencia: NFR-SEG-1 a NFR-SEG-9 de la ERS, OWASP Top 10, ISO/IEC 27001. El proyecto declara en su package.json ser 'intencionalmente vulnerable'; estos casos buscan localizar y documentar cada debilidad.

ID	Requisito	Escenario / Pasos	Datos	Resultado esperado	Prioridad
CP-SEG-01 (D)	NFR-SEG-2	Registrar un usuario y consultar la columna 'contrasena' en la tabla usuarios	SELECT contrasena	Debe verse un hash bcrypt/Argon2. Desvío crítico: la contraseña se guarda y compara en texto plano (auth.js: user.contrasena !== password)	A
CP-SEG-02 (D)	NFR-SEG-1	Interceptar tráfico entre SPA y API	proxy	Todo el tráfico debe ir por TLS. Desvío: el servidor escucha en HTTP plano; cors() abierto a cualquier origen	A
CP-SEG-03 (D)	NFR-SEG-4 / RB-2	Invocar DELETE /usuarios/:id, POST/PUT/DELETE /roles sin token	sin Authorization	Debe responder 401/403. Desvío crítico: estos endpoints no verifican autenticación ni rol; GET /roles y GET /roles/:id son totalmente públicos	A
CP-SEG-04 (D)	NFR-SEG-8	GET /pacientes/buscar/rut/:rut sin token	RUT de un paciente	Debe requerir autenticación. Desvío crítico: devuelve la ficha clínica completa (p.*) de cualquier paciente sin autenticación	A
CP-SEG-05	NFR-SEG-5	Inyección SQL en parámetros de ruta/query (id, rut, paciente_id)	' OR 1=1 --	Sin ejecución de SQL malicioso. Esperado: mitigado (consultas parametrizadas \$1); confirmar con sqlmap	A
CP-SEG-06	NFR-SEG-5	XSS almacenado: guardar <script> en notas/observaciones/diagnosis de un examen y visualizarlo en la SPA	payload script	El contenido se escapa al renderizar; no se ejecuta script	A
CP-SEG-07	NFR-SEG-5	CSRF sobre operaciones de escritura	petición cross-site	El token va por cabecera Authorization (no cookie), reduciendo CSRF; validar ausencia de endpoints que confíen en cookies y revisar cabeceras de seguridad	M
CP-SEG-08 (D)	NFR-SEG-6	Forzar error 500 en varios endpoints y revisar el cuerpo de la respuesta	entrada inválida	No debe exponerse traza ni mensaje interno. Desvío: 'glosa' = err.message/err.toString() en casi todos los catch; console.error vuelca el error completo	A
CP-SEG-09 (D)	NFR-SEG-9	Revisar gestión del secreto JWT y expiración	código + repo	Secreto fuera del repositorio, fuerte, rotomable. Desvío: JWT_SECRET está en .env versionado y en el README; fallback en código a 'inseguro'	A
CP-SEG-10 (D)	NFR-SEG-3	Verificar cifrado en reposo de datos sensibles (ficha clínica, documentos BYTEA)	inspección BD	Datos sensibles cifrados o BD con cifrado a nivel de volumen. Desvío: todo se almacena en claro	A
CP-SEG-11 (D)	NFR-SEG-5	Ataque de fuerza bruta al login (100 intentos/min)	script	Debe existir rate limiting, captcha o bloqueo temporal de cuenta. Desvío: no hay ninguna protección	A
CP-SEG-12 (D)	NFR-SEG-4 / RB	Un usuario con rol 'medico' hace PUT /usuarios/:id { rol_id: <admin> } sobre otro usuario	token de médico	Solo un admin debería cambiar roles. Desvío: updateUsuarioSistemaMedico permite a 'medico' cambiar roles de otros usuarios (escalamiento de privilegios)	A
CP-SEG-13	NFR-SEG-4	IDOR: paciente A solicita GET /exámenes/:id y GET /documentos/:id de paciente B	IDs ajenos	403 'Solo puede ver sus propios...'. Esperado: mitigado; confirmar en todos los sub-recursos	A
CP-SEG-14 (D)	RF-5 / NFR-SEG-6	POST /auditoria con acción y detalles arbitrarios desde un usuario cualquiera	{accion:'...', detalles:'...'}	La auditoría debería ser generada solo por el sistema. Desvío: cualquier usuario autenticado puede insertar registros arbitrarios (contaminación del log)	M
CP-SEG-15	NFR-SEG-5	Subir un ejecutable renombrado a .pdf / .png	archivo con cabecera PE	Debe rechazarse por validación de contenido real (magic bytes). Actual: solo se valida el mimetype declarado por el cliente	M
CP-SEG-16 (D)	NFR-SEG-6	Acceder a /docs y /openapi.json sin autenticación	navegador	Documentación de la API accesible sin control; evaluar restringir en producción	B

7. Casos de prueba de cumplimiento normativo

ID	Requisito	Escenario / Pasos	Datos	Resultado esperado	Prioridad
CP-CUM-01 (D)	Ley 21.719 (minimización/exactitud)	Registro con RUT: revisar los datos que crea el sistema para el paciente	registro con rut	Desvío: se crea el paciente con datos ficticios (fecha '2000-01-01', sexo 'M', apellido vacío); datos inexactos por defecto	M
CP-CUM-02	Ley 21.719 (transparencia/consentimiento)	Verificar que la política de privacidad y los términos son accesibles antes del registro y describen finalidad y datos tratados	páginas Política/Términos	Contenido presente, claro y enlazado desde el registro	M
CP-CUM-03	Ley 21.719 (derecho de acceso)	El paciente puede ver y descargar todos sus datos clínicos	flujo paciente	Cubierto por RF-4.1/4.2; verificar completitud	M
CP-CUM-04 (D)	Ley 21.719 (rectificación/supresión)	Eliminación de paciente/examen/documento	DELETE de cada entidad	Debe ser lógica, reversible y trazable. Desvío: son borrados físicos (DELETE ... RETURNING), con CASCADE sobre exámenes y documentos	A
CP-CUM-05	Trazabilidad (materia)	Comprobar la matriz requisito <-> caso <-> evidencia	matriz sección 9	Cada RF/NFR tiene al menos un caso y resultado registrado	A
CP-CUM-06	Integridad de auditoría (RF-5 / ISO 27001 A.12.4)	Intentar modificar o borrar registros de la tabla auditoría vía API	endpoints	No existe endpoint de update/delete de auditoría (correcto); verificar que POST no permita falsificar usuario_id	M
CP-CUM-07 (D)	ISO/IEC 25010 (mantenibilidad)	Revisar duplicación de código de seguridad	getUserFromAuthHeader / requireRole	Desvío: ambas funciones están copiadas en 5+ archivos de rutas en lugar de un middleware único; además persisten restos del modelo 'empresas' (código muerto de otro caso)	M
CP-CUM-08 (D)	ISO/IEC 27001 (A.10 criptografía)	Consolidar evidencia de cifrado en tránsito y en reposo	CP-SEG-01/02/10	Desvío: incumple hashing de contraseñas, TLS y cifrado en reposo simultáneamente	A

8. Hallazgos de la revisión estática (resumen ejecutivo)

Severidad según impacto sobre datos clínicos y facilidad de explotación. Estos hallazgos alimentan los casos de las secciones 4–7 y deben corregirse antes de considerar el sistema apto.

ID	Sev.	Hallazgo	Ubicación	Requisito / norma
H-01	Crítica	Contraseñas almacenadas y comparadas en texto plano (sin bcrypt).	BACKEND/src/routes/auth.js:21, :111; sql/init.sql:7	NFR-SEG-2, Restr. 2.4, Ley 21.719
H-02	Crítica	DELETE /usuarios/:id sin autenticación ni verificación de rol.	BACKEND/src/routes/users.js:571	NFR-SEG-4, RF-2.7, RB-2
H-03	Crítica	Endpoint de búsqueda por RUT expone la ficha clínica completa sin token.	BACKEND/src/routes/pacientes.js:249	NFR-SEG-8, Ley 21.719
H-04	Crítica	Rutas de /roles sin control de acceso (POST/PUT/DELETE) y sin validación de entrada.	BACKEND/src/routes/roles.js:18-92	NFR-SEG-4
H-05	Alta	Sin TLS: la API escucha en HTTP y CORS está abierto a todo origen.	BACKEND/src/app.js:21, :50	NFR-SEG-1
H-06	Alta	Escalamiento de privilegios: rol 'medico' puede cambiar roles de otros usuarios.	BACKEND/src/routes/users.js:484-532	NFR-SEG-4, RB
H-07	Alta	Secreto JWT versionado en .env y publicado en README; fallback 'inseguro'.	BACKEND/.env:3; README.md:30; routes/*.js	NFR-SEG-9
H-08	Alta	Respuestas de error exponen err.message / stack ('glosa') al cliente.	Todos los bloques catch de las rutas	NFR-SEG-6, NFR-USAB-3
H-09	Alta	Logout no revoca el JWT; la sesión sigue válida hasta expirar.	FRONTEND/src/context/AuthContext.jsx:65; sin blacklist en backend	RF-1.2
H-10	Alta	Sin protección contra fuerza bruta en el login (ni rate limit ni bloqueo).	BACKEND/src/routes/auth.js:10	NFR-SEG-5
H-11	Alta	Sin cifrado de datos sensibles en reposo (ficha clínica y documentos BYTEA).	sql/init.sql; routes/documentos.js:97	NFR-SEG-3, ISO 27001
H-12	Alta	Rendimiento degradado a propósito: delayMiddleware(5000) en listados y creación.	routes/pacientes.js:145; routes/examen.es.js:46,99,330; routes/documentos.js:66	NFR-PERF-1/2
H-13	Media	Auditoría rota en DELETE usuario y en /roles: se inserta texto en usuario_id (BIGINT FK).	routes/users.js:584; routes/roles.js:25,65,83	RF-5.1
H-14	Media	POST /auditoria permite a cualquier usuario insertar registros arbitrarios.	routes/audit.js:19	RF-5.1, integridad de log
H-15	Media	Eliminaciones físicas con CASCADE; la ERS exige eliminación lógica con confirmación.	routes/examen.es.js:396; routes/pacientes.js:387; routes/users.js:571	RF-3.3, Ley 21.719
H-16	Media	Política de contraseñas del registro (min 6, sin complejidad) más débil que la ERS (min 12 + complejidad).	BACKEND/src/validations/auth.js:21	Restr. 2.4
H-17	Media	Formatos de documento aceptados (PDF/JPG/PNG) no incluyen DOC ni PPT exigidos por la ERS; validación solo por mimetype declarado.	routes/documentos.js:16-27	RF-4.3, NFR-SEG-5
H-18	Media	Código de autenticación/autorización duplicado en 5+ archivos; restos del modelo 'empresas' (código muerto).	routes/auth.js, users.js, pacientes.js, examen.es.js, documentos.js, roles.js, audit.js	ISO 25010 (mantenibilidad)
H-19	Baja	Swagger UI y /openapi.json accesibles sin autenticación.	BACKEND/src/app.js:37-41	NFR-SEG-6
H-20	Baja	Credenciales por defecto triviales (admin/admin, medico/medico, paciente/paciente) mostradas en la propia UI.	FRONTEND/src/pages/auth/Login.jsx:191-201	NFR-SEG-2

9. Matriz de trazabilidad

Requisito	Casos de prueba	Hallazgos relacionados
RF-1 Autenticación y sesión	CP-F-01, CP-F-02, CP-F-03, CP-F-04	H-01, H-07, H-09, H-10
RF-2 Registro / gestión de usuarios	CP-F-05..CP-F-14	H-02, H-06, H-16
RF-3 Gestión de exámenes	CP-F-15, CP-F-16, CP-F-17	H-15
RF-4 Visualización de información médica	CP-F-18, CP-F-19, CP-F-20, CP-F-21	H-11, H-17
RF-5 Auditoría	CP-F-22, CP-SEG-14, CP-CUM-06	H-13, H-14
NFR-SEG Seguridad	CP-SEG-01..CP-SEG-16	H-01..H-11, H-14, H-17, H-19, H-20
NFR-PERF Rendimiento	CP-NF-01, CP-NF-02, CP-NF-03	H-12
NFR-USAB Usabilidad/accesibilidad	CP-NF-04, CP-NF-05, CP-NF-08	H-08
NFR-DIS Disponibilidad	CP-NF-06	—
NFR-COMPAT Compatibilidad	CP-NF-07	—
Cumplimiento legal (Ley 19.628/21.719)	CP-CUM-01..CP-CUM-08	H-01, H-03, H-11, H-15

10. Gestión de defectos y riesgos

10.1 Ciclo de vida del defecto

Nuevo -> Asignado -> En corrección -> Listo para repueba -> Cerrado / Reabierto. Cada defecto registra: identificador, caso de prueba origen, severidad, prioridad, pasos de reproducción, evidencia (request/response, captura, consulta SQL) y requisito afectado. Herramienta sugerida: GitHub Issues o Jira.

10.2 Riesgos del proyecto de pruebas

Riesgo	Mitigación
El código es 'intencionalmente vulnerable': gran volumen de defectos esperados.	Priorización basada en riesgo (datos clínicos y auth primero); reporte por severidad; no bloquear por hallazgos de severidad baja.
Ausencia de pruebas automatizadas y de datos de prueba estables.	Construir seed reproducible desde init.sql; automatizar la colección Postman/Newman en CI.
Delays artificiales (5 s) enmascaran el rendimiento real.	Medir con y sin delayMiddleware; reportar la latencia neta de la lógica.
Entorno único compartido puede contaminar resultados.	Base de datos efímera por ejecución (Testcontainers) y limpieza entre suites.

11. Conclusión

El plan cubre los cinco requisitos funcionales y los cinco grupos de requisitos no funcionales de la ERS de Cuidarte+, más los aspectos de seguridad y de cumplimiento legal exigidos por la asignatura. La revisión estática ya identificó 20 hallazgos —4 de severidad crítica— concentrados en autenticación, control de acceso y protección de datos clínicos. Ninguno de los criterios de aceptación de seguridad de la ERS (hashing, TLS, cifrado en reposo, sin hallazgos críticos) se cumple en el estado actual, por lo que el sistema **no es apto** hasta remediar al menos los hallazgos H-01 a H-11. La ejecución de los casos aquí definidos permitirá confirmar cada desviación, verificar las correcciones y construir la evidencia de trazabilidad para el cierre de la evaluación.